

IBEROTECH

Manual Técnico

Autores: Antonio Contreras Montana y Alexandro Castro Serrano
ASIR 2 - Proyecto Intermodular | IES Albarregas, Mérida

1. Introducción

1.1 Descripción del Proyecto

IberoTech es una empresa ficticia del sector de la ciberseguridad con sede en Mérida. El proyecto ha sido diseñado e implementado por Antonio Contreras Montana y Alexandro Castro Serrano en el marco del Proyecto Final del Ciclo Formativo de Grado Superior en Administración de Sistemas Informáticos en Red (ASIR 2) en el IES Albarregas.

IberoTech ofrece cuatro líneas de servicio: Consultoría, Auditoría, Diseño de infraestructuras seguras y Análisis de vulnerabilidades. La infraestructura cubre tanto la red interna de oficina como los servicios públicos de producción en AWS.

1.2 Módulos del Proyecto

Modulo	Tecnología Principal
Infraestructura AWS (5 capas)	EC2, VPC, NAT Gateway, Elástica IP
Windows Server + Active Directory	Windows Server 2016, AD DS, GPO, DHCP, DNS, FTP
Base de Datos	MariaDB con replicación maestro-esclavo
Aplicación Web	PHP, Apache2, Nginx, HAProxy, NFS
Aplicación Python	Python 3, Tkinter, Nmap, ReportLab
Scripts Linux	Bash, SSH

1.3 Tecnologías Utilizadas

Tecnología	Uso en el Proyecto
Windows Server 2016	Controlador de Dominio, Active Directory, DHCP, DNS, FTP
Debian Linux	Todos los servidores de servicios en red (AWS)
Apache2	Servidores web (Capa 2)
Nginx	Balanceador de carga (Capa 1)
HAProxy	Proxy SQL hacia clúster MariaDB (Capa 4)
MariaDB	Base de datos con replicación maestro-esclavo (Capa 5)
PHP	API y paneles de administración/cliente
Python + Tkinter	Aplicación de escritorio: escáner de puertos con Nmap
AWS (EC2, VPC)	Infraestructura publica en la nube

2. Arquitectura de la Infraestructura AWS

2.1 Visión General

La infraestructura publica de IberoTech se despliega en Amazon Web Services (AWS) y sigue un modelo de defensa en profundidad con cinco capas de seguridad aisladas mediante subredes independientes dentro de una VPC (Virtual Private Cloud) con rango 10.0.0.0/16.

El único servidor con IP publica es el Balanceador Nginx (IP elástica). El resto de servidores están en subredes privadas y acceden a Internet a través de una NAT Gateway.

2.2 Modelo de 5 Capas de Seguridad

Capa	Componente	IP Privada	Función
Capa 1	Nginx Balanceador	10.0.1.28 (IP publica elástica)	Punto de entrada único. Distribuye trafico entre WEB1 y WEB2
Capa 2	Apache WEB1	10.0.2.123	Servidor web. Sirve la aplicación PHP desde NFS
Capa 2	Apache WEB2	10.0.2.87	Servidor web redundante. Mismo contenido que WEB1
Capa 3	NFS Server	10.0.3.240	Almacenamiento compartido. Aloja la web PHP y la API
Capa 4	HAProxy	10.0.4.34	Proxy SQL. Puerto 3306 escritura, 3307 lectura
Capa 5	MariaDB BD1 (PRIMARY)	10.0.5.118	Base de datos principal. Recibe escrituras
Capa 5	MariaDB BD2 (SECONDARY)	10.0.5.231	Replica de BD1. Solo lectura

2.3 Replicación MariaDB

Se utiliza replicación maestro-esclavo de MariaDB. BD1 es el nodo PRIMARY (maestro) y BD2 es el nodo SECONDARY (esclavo). Todos los datos se escriben en BD1 y se replican automáticamente a BD2.

HAProxy expone dos puertos:

- Puerto 3306 (escritura): dirige las conexiones a BD1. BD2 actúa como backup en caso de caída de BD1.
- Puerto 3307 (lectura): distribuye las consultas entre BD1 y BD2 en modo round-robin.

2.4 Flujo de una Petición Web

Pas o	Componente	Acción
1	Usuario externo	Accede a labs-iberotech.ddns.net por HTTP (puerto 80)
2	Nginx - Capa 1	Recibe la petición y la reenvía a WEB1 o WEB2 por round-robin
3	Apache - Capa 2	Procesa la petición PHP y obtiene los archivos desde NFS
4	NFS - Capa 3	Proporciona el contenido (PHP, HTML, API) al servidor Apache
5	HAProxy - Capa 4	Recibe consultas SQL desde Apache y las dirige a MariaDB

Pas o	Componente	Acción
6	MariaDB - Capa 5	Responde a la consulta SQL. El dato recorre el camino inverso

2.5 Grupos de Seguridad AWS

Cada servidor tiene asignado un grupo de seguridad que controla el tráfico entrante y saliente. La regla general es que cada capa solo puede comunicarse con la capa adyacente.

Grupo	Entrada relevante	Salida relevante
SG-balanceador	HTTP 80 desde 0.0.0.0/0, SSH 22 desde 10.0.0.0/16	HTTP 80 hacia 10.0.2.0/24
SG-web	HTTP 80 desde 10.0.1.0/24, SSH 22 desde 10.0.0.0/16	NFS 2049 hacia 10.0.3.0/24, MySQL 3306/3307 hacia 10.0.3.0/24, SMTP 587 hacia 0.0.0.0/0
SG-nfs	NFS 2049 desde 10.0.2.0/24, SSH 22 desde 10.0.0.0/16	MySQL 3306/3307 hacia 10.0.4.0/24
SG-proxy	MySQL 3306/3307 desde 10.0.3.0/24, SSH 22 desde 10.0.0.0/16	MySQL 3306/3307 hacia 10.0.5.0/24
SG-bd	MySQL 3306 desde 10.0.4.0/24 y 10.0.5.0/24, SSH 22 desde 10.0.0.0/16	MySQL 3306 hacia 10.0.5.0/24 (replicación)

3. Aplicación Web PHP

3.1 Descripción

La aplicación web de IberoTech esta desarrollada en PHP y reside en el servidor NFS en /var/nfs/shared/. Los servidores Apache (WEB1 y WEB2) montan esta carpeta por NFS en /var/www/shared/, de forma que ambos sirven exactamente el mismo contenido.

3.2 Estructura de Archivos

Ruta	Descripción
/var/nfs/shared/index.html	Web publica con login modal y formulario de contacto
/var/nfs/shared/admin.php	Panel de administración (empleados/admins)
/var/nfs/shared/cliente.php	Panel del cliente
/var/nfs/shared/api/login.php	Autenticación. Empleados por Nombre, clientes por CIF
/var/nfs/shared/api/logout.php	Cierra la sesión y redirige al inicio
/var/nfs/shared/api/clientes.php	CRUD de clientes (listar, crear, eliminar)
/var/nfs/shared/api/contacto.php	Formulario de contacto. Crea cliente y envía credenciales por correo
/var/nfs/shared/api/contratos.php	Gestión de contratos y catalogo de servicios
/var/nfs/shared/api/incidencias.php	Listado y resolución de incidencias (admin)
/var/nfs/shared/api/mis_incidencias.php	Incidencias del cliente logado
/var/nfs/shared/api/nueva_incidentia.php	El cliente crea una nueva incidencia
/var/nfs/shared/api/subir_web.php	El admin sube un HTML para reemplazar el index
/var/nfs/shared/api/descargar_app.php	Sirve el RAR de la app de escritorio al cliente
/var/nfs/shared/api/gestor.php	Ejecuta comandos SSH en las maquinas AWS (estado, logs, backup)
/var/nfs/shared/api/status.php	Comprueba si la BD esta funcionando
/var/nfs/shared/api/config/db.php	Configuración de conexión a MariaDB vía HAProxy
/var/nfs/shared/api/config/mail.php	Configuración del correo vía Postfix/Brevo
/var/nfs/shared/app/iberotech_app.rar	Aplicación de escritorio para descargar

3.3 Sistema de Sesiones

Las sesiones PHP se almacenan en la base de datos MariaDB en la tabla php_sessions, implementado en db.php mediante session_set_save_handler(). Esto garantiza que las sesiones son compartidas entre WEB1 y WEB2 sin problemas de sincronización.

3.4 Correo Automático

Cuando un cliente rellena el formulario de contacto o es creado desde el panel de administración, el sistema genera una contraseña aleatoria con bcrypt y envía un correo con las credenciales de acceso.

El correo se envía a través de Postfix configurado en WEB1 y WEB2 como relay SMTP hacia Brevo (antes Sendinblue). El remitente verificado es `iberotech.proyectoasir@gmail.com`.

4. Base de Datos Relacional

4.1 Descripción

La base de datos iberotech gestiona las operaciones internas y externas de la empresa: departamentos, empleados, clientes, contratos de servicio e incidencias de ciberseguridad.

4.2 Tablas Principales

Tabla	Campos Clave	Descripción
Departamento	ID_Departamento (PK)	Departamentos de la empresa
Empleado	ID_Empleado (PK), ID_Departamento (FK)	Trabajadores. Pueden iniciar sesión con su Nombre
Cliente	ID_Cliente (PK), CIF (UNIQUE)	Clientes. Inician sesión con su CIF
Catalogo	ID_Tipo_Servicio (PK)	Tipos de servicio ofrecidos con precio
Contrato	ID_Contrato (PK), ID_Cliente (FK), ID_Empleado (FK)	Contratos entre cliente y empleado responsable
Incidencia	ID_Incidencia (PK), ID_Contrato (FK)	Incidencias vinculadas a contratos activos
php_sessions	id, data, last_activity	Sesiones PHP almacenadas en BD (compartidas entre WEB1 y WEB2)

4.3 Credenciales de Conexión

Parámetro	Valor
Host escritura	10.0.4.34:3306 (HAProxy)
Host lectura	10.0.4.34:3307 (HAProxy)
Usuario	app_user
Base de datos	iberotech

5. Windows Server y Active Directory

5.1 Descripción del Dominio

El dominio IberoTech.es centraliza la gestión de todos los usuarios y equipos de la empresa bajo Windows Server 2016. La arquitectura es de dominio único con un solo sitio Active Directory.

Parámetro	Valor
Nombre del dominio	IberoTech.es
Sistema operativo del DC	Windows Server 2016
Nombre del servidor	WIN-EH0B856J2LR
IP del servidor	192.168.10.10
Red del servidor	192.168.10.0/24
Red de clientes	192.168.20.0/24
Router Debian	192.168.10.1 (enp0s8) / 192.168.20.1 (enp0s9)

5.2 Estructura de Unidades Organizativas (OUs)

El dominio se segmenta en cinco Unidades Organizativas, cada una correspondiente a un departamento real de la empresa.

OU	Grupos de seguridad	Descripción
Depart_Informaticos	SG-INFO-WEB, SG-INFO-SER	Personal técnico de informática
Depart_Financiero	SG-FINANCIERO	Departamento financiero y contabilidad
Depart_Tecnico	SG-TECNICO	Soporte técnico a clientes
Depart_Marketing	SG-MARKETING	Marketing y comunicación
Depart_Juridico	SG-JUR-PRO, SG-JUR-CLI	Departamento jurídico

5.3 Nomenclatura de Usuarios

Tipo	Formato	Ejemplo
Informáticos	INFO-Nombre	INFO-Antonio, INFO-Alexandro
Financiero	FINAN-Nombre	FINAN-Carlos, FINAN-Mario
Técnico	TECN-Nombre	TECN-Jaime, TECN-Rafa
Marketing	MK-Nombre	MK-Daniel, MK-Felipe
Jurídico	JUR-Nombre	JUR-Clara, JUR-Eva
Contraseñas	Iberotech-PREFIJO-ID.	Iberotech-INFO-1., Iberotech-FINAN-2.

5.4 Política de Contraseñas

Las cuentas de dominio deben cumplir la siguiente política configurada en el Active Directory:

Requisito	Valor
Longitud minima	8 caracteres
Composicion	Mayusculas + numeros + simbolos
Formato	Iberotech-[Departamento]-[ID].
Cambio en primer inicio	Si (obligatorio)

5.5 Script de Creacion de Usuarios

Se ha desarrollado un script PowerShell interactivo (usuarios.ps1) que permite crear usuarios en AD de forma guiada. El script realiza los siguientes pasos:

- Selecccion del departamento (1-5)
- Introduccion del nombre real del usuario
- Generacion automatica del nombre de usuario con el prefijo del departamento
- Generacion automatica de contrasena en formato Iberotech-PREFIJO-ID.
- Selecccion del grupo de seguridad
- Verificacion de que el usuario no existe antes de crearlo
- Verificacion de que el grupo existe antes de asignar
- Configuracion de horas de acceso: 07:00 - 18:00
- Muestra resumen con datos de acceso para entregar al usuario

5.6 Servicios de Red

DHCP

El servidor DHCP asigna automaticamente IPs a los equipos de empleados en la red 192.168.20.0/24.

Parametro	Valor
Rango	192.168.20.20 - 192.168.20.200
Mascara	255.255.255.0
Puerta de enlace	192.168.20.1 (Router Debian)
DNS	192.168.10.10 (Windows Server)
Dominio	Iberotech.es

DNS

El servicio DNS se instala automaticamente con AD DS y resuelve los nombres del dominio Iberotech.es. Los equipos clientes apuntan a 192.168.10.10 como servidor DNS.

FTP

El servidor FTP permite a los empleados acceder a recursos internos segun su grupo de seguridad. Solo es accesible desde la red privada.

Carpeta FTP	Grupo con acceso	Contenido
C:\FTP\manuales	SG-TECNICO	Manual tecnico y de usuario de la aplicacion
C:\FTP\scripts	SG-INFO-WEB	Scripts de aprovisionamiento .sh de los servidores AWS

Los permisos se aplican mediante NTFS: cada carpeta tiene restringido el acceso unicamente al grupo correspondiente. La autentificacion FTP usa las credenciales de dominio (autenticacion basica, sin acceso anonimo).

6. Políticas de Grupo (GPO)

Las GPOs se aplican por departamento para demostrar el control de acceso diferenciado. Los informáticos no tienen restricciones ya que son los administradores del sistema.

6.1 GPOs por Departamento

Departamento	Bloquear Panel de Control	Bloquear CMD	Fondo Corporativo
Informáticos (OU=Depart_Informáticos)	No (sin restricción)	No (sin restricción)	Si
Financiero (OU=Depart_Financiero)	Si	Si	Si
Técnico (OU=Depart_Técnico)	No	Si	Si
Marketing (OU=Depart_Marketing)	No	Si	Si
Jurídico (OU=Depart_Jurídico)	Si	Si	Si

6.2 Descripción de las Restricciones

Bloquear Panel de Control

Ruta: Configuración de usuario > Plantillas administrativas > Panel de control > Prohibir acceso al Panel de control y configuración de PC. Aplicado a Jurídico y Financiero para evitar modificaciones del sistema.

Bloquear CMD

Ruta: Configuración de usuario > Plantillas administrativas > Sistema > Impedir el acceso al símbolo del sistema. Aplicado a todos salvo Informáticos para evitar ejecución de comandos no autorizados.

Fondo Corporativo

Ruta: Configuración de usuario > Plantillas administrativas > Escritorio > Escritorio activo > Tapiz de escritorio activo. Se aplica el logo de IberoTech como fondo en todos los equipos del dominio. El usuario no puede cambiarlo.

6.3 Horas de Acceso

Los usuarios normales tienen configuradas restricciones horarias mediante el script de creación de usuarios. El acceso al dominio está permitido de 07:00 a 18:00 todos los días de la semana. Esta restricción se aplica directamente sobre el atributo logonHours de cada cuenta en AD.

7. Aplicacion de Escritorio Python

7.1 Descripcion

La aplicacion de escritorio es un escaner de puertos desarrollado en Python por Alexandro Castro. Permite escanear puertos de un equipo, detectar puertos peligrosos abiertos y exportar el resultado a un informe PDF.

7.2 Tecnologias

Componente	Tecnologia	Funcion
Interfaz grafica	Tkinter	Ventanas y formularios
Escaneo de puertos	Nmap (python-nmap)	Deteccion de puertos abiertos
Generacion de PDF	ReportLab	Exportacion del informe
Empaquetado	PyInstaller	Compilacion a .exe para Windows

7.3 Distribucion

La aplicacion se distribuye como archivo Iberotech_app.rar disponible en /var/nfs/shared/app/ en el servidor NFS. Los clientes registrados pueden descargarsela desde su panel en la web de IberoTech a traves del enlace de descarga protegido por sesion (descargar_app.php).

8. Seguridad del Sistema

8.1 Modelo de Defensa en Profundidad

IberoTech implementa un modelo de defensa en profundidad donde cada capa aplica sus propias medidas de seguridad independientes.

Capa	Mecanismo	Proteccion
Identidad (AD)	Active Directory + GPOs	Control de usuarios, permisos y configuracion de equipos por departamento
Red AWS	Grupos de seguridad por capa	Cada capa solo comunica con la adyacente. Puertos minimos necesarios
Acceso web	Sesiones PHP en BD	Sesiones compartidas entre WEB1 y WEB2. Proteccion contra accesos no autorizados
Base de datos	HAProxy + red 10.0.5.0/24 aislada	MariaDB invisible desde Internet. Solo accesible desde HAProxy
Correo	Postfix + Brevo SMTP relay	Correo autenticado con remitente verificado. No se expone el servidor directamente

8.2 Proteccion frente a Ataques Comunes

Tipo de Ataque	Medida Implementada
Acceso no autorizado a web	Sesiones PHP obligatorias. Sin sesion, redireccion al login
Inyeccion SQL	Consultas preparadas (PDO) en toda la API PHP. Nunca concatenacion directa
Escaneo de puertos	Puertos criticos (3306, 3307, 4567) invisibles desde Internet por segmentacion en 5 capas
Acceso entre capas	Grupos de seguridad AWS restringen el trafico entre subredes
Acceso no autorizado por FTP	Autenticacion basica con credenciales de dominio. Permisos NTFS por grupo

9. Glosario de Terminos

Termino	Definicion
Active Directory (AD)	Servicio de directorio de Microsoft. Centraliza la gestion de usuarios, equipos, grupos y politicas de seguridad del dominio IberoTech.es
Apache2	Servidor web utilizado en la Capa 2 para procesar peticiones PHP y servir contenido desde el NFS
DHCP	Dynamic Host Configuration Protocol. Servicio del Windows Server que asigna automaticamente direcciones IP a los equipos de la red interna
DNS	Domain Name System. Traduce nombres de dominio a direcciones IP. Configurado en Windows Server para el dominio IberoTech.es
FTP	File Transfer Protocol. Servidor de archivos interno. Los empleados acceden segun su grupo de seguridad
GPO	Group Policy Object. Directivas de grupo de Windows Server que aplican configuraciones y restricciones de seguridad a usuarios y equipos del dominio
HAProxy	High Availability Proxy. Balanceador de carga TCP/SQL. Expone BD en puertos 3306 (escritura) y 3307 (lectura)
MariaDB	Sistema Gestor de Bases de Datos Relacionales. Configurado en replicacion maestro-esclavo (BD1 PRIMARY, BD2 SECONDARY)
NAT Gateway	Componente de AWS que permite a las instancias privadas acceder a Internet sin tener IP publica
NFS	Network File System. Sistema de ficheros compartido. Permite que WEB1 y WEB2 sirvan exactamente el mismo contenido
Nginx	Servidor web y proxy inverso. Unico punto de entrada con IP publica elastica. Distribuye trafico entre WEB1 y WEB2
OU	Organizational Unit. Contenedor en Active Directory que agrupa usuarios de un mismo departamento
PHP	Lenguaje de programacion del lado del servidor utilizado para la API y los paneles de administracion y cliente
Postfix	Servidor de correo instalado en WEB1 y WEB2 configurado como relay SMTP hacia Brevo para el envio de correos automaticos
Replicacion maestro-esclavo	Configuracion de MariaDB donde BD1 (maestro) recibe escrituras y las replica automaticamente a BD2 (esclavo)
SSH	Secure Shell. Protocolo de acceso remoto cifrado. Usado por gestor.php para ejecutar comandos en los servidores AWS
VPC	Virtual Private Cloud. Red virtual aislada en AWS donde se despliega la infraestructura publica de IberoTech (10.0.0.0/16)